
第 6 章 操作系统安全

一、填空题：

- 1、操作系统面临的安全威胁包括病毒、蠕虫、木马、逻辑炸弹、隐蔽通道、天窗。
- 2、操作系统的安全目标是：对系统的用户进行身份认证，依据安全策略对用户操作进行访问控制，阻止用户对系统资源的非法访问，监督系统运行的安全，保证系统自身的安全性和完整性。
- 3、操作系统的存储保护中，数据存储单元可以分为字、字块、页面、或段。
- 4、操作系统的硬件安全机制包括：存储保护、运行保护和I/O 保护。

二、选择题：

- 1、以下可以进行网络攻击的威胁是：（ ABCDEF ）
A. 病毒；B. 蠕虫；C. 木马；D. 逻辑炸弹；E. 隐蔽通道；F. 天窗
- 2、以下攻击具有传染性的是（ AB ）
A. 病毒；B. 蠕虫；C. 木马；D. 逻辑炸弹；E. 隐蔽通道；F. 天窗
- 3、以下属于最小特权保护机制的是（ CD ）
A. 将系统用户的角色分为管理员角色和一般用户角色；
B. 将系统用户的角色分为 root 角色和一般用户角色；
C. 将系统用户的角色分为系统安全管理员、系统安全审计管理员、系统安全数据复制管理员和一般用户；
D. 不给用户分配超过执行任务所需特权以外的权限。

三、简答题：

- 1、病毒和蠕虫的区别？他们的传播途径分别是什么？

答：

- （1）病毒是能够自我复制的计算机程序，破坏计算机功能，具有隐蔽性、潜伏性、破坏性、寄生性、传染性；
- （2）蠕虫具有传染性和复制功能，但与病毒不同，可以独立存在，无需寄生在某个程序之中；
- （3）传播途径：不同于病毒通过被感染文件运行来感染目标文件，蠕虫是利用系统自身存在的漏洞来传染。

- 2、简要说明存储管理中，虚拟地址空间和物理地址空间是如何对应的？

答：虚拟地址会通过页表映射到物理内存，页表由操作系统维护并被处理器引用，每个进程都有自己的页表。

四、问答题：

1、隐蔽通道划分成哪两类？每类一个举例，说明工作原理。

答：

(1) 隐蔽存储通道。

工作原理：隐蔽存储通道在系统中通过两个进程利用不受安全策略控制的存储单元传递信息，前一个进程通过改变存储单元的内容发送信息，后一个进程通过观察存储单元的变化来接收信息。

例如：BLP 模型的隐蔽通道问题；

(2) 隐蔽定时通道。

工作原理：隐蔽定时通道在系统中通过两个进程利用一个不受安全策略控制的广义存储单元传递信息。前一个进程通过改变广义存储单元的内容发送信息，后一个进程通过观察广义单元的变化接受信息，并利用如时钟这样的坐标进行测量。

2、操作系统的硬件安全机制中，存储单元越小，存储保护的精度越高。那是不是可以认为存储单元越小越好？存储单元过大除了存储保护的精度低外，还会对系统造成什么影响？

答：不是。

(1) 虽然存储保护的精度取决于保护单元的大小，但如果存储单元过小会占用更多的页面，导致对应的页表占用更多内存，且会降低从页面中切换的效率；

(2) 存储单元过大可以提高页面切换的效率，占用更少的页面，但也会造成存储单元利用率不高，浪费一定的存储空间。

第 6 章 操作系统安全（第二次作业及答案）

一、填空题

- 1、TCSEC（橘皮书）标准中，操作系统的安全级别从高到低分为：A1 级、B3 级、B2 级、B1 级、C2 级、C1 级 和 D 级。
- 2、安全访问令牌分为：主令牌 和 模拟令牌。
- 3、在 Windows 系统中，访问控制列表可以分为 自主访问控制列表 和 系统访问控制列表 两类。

二、选择题

- 1、windows7 操作系统访问控制策略包括（ ABC ）
A. 自主访问控制策略；
B. 基于角色的访问控制策略
C. 强制访问控制策略；
D. 基于属性的访问控制策略。
- 2、安全访问令牌在以下哪个模块中产生（ A ）
A. 本地安全认证（LSA）模块；
B. 安全账户管理（SAM）模块；
C. Netlogon 模块；
D. 安全引用监控器（SRM）模块。
- 3、安全访问令牌可以与以下哪些实体关联（ABD ）
A、进程； B. 用户； C. 资源； D. 线程； E. 被访问对象
- 4、Linux 系统的用户口令保存在以下文件中（ B ）
A. passwd 文件； B.shadow 文件； C.useradd 文件； D. group 文件
- 5、Linux 系统中，以下哪些设备采用块设备文件（ AB ）
A.U 盘； B 硬盘； C.打印机； D.传真

三、简答题

- 1、安全审计时，不仅要记录失败事件，还要记录成功事件，为什么？
答：
(1) 记录失败事件可以查看哪些操作失败了，从而分析失败的原因；
(2) 记录成功实践是因为，攻击者通过非法手段获得访问权限后，也会产生安全事件，通过记录成功实践可以进行事件溯源。
2. 简述 Android 和 Linux 操作系统安全机制之间的异同。

答:

Android 平台的基础是 Linux 内核, 因此 Android 的安全机制也是建立在 Linux 内核的安全基础之上的, 它为 Android 系统提供了 4 个方面的安全支持: 基于用户权限的安全模型, 进程隔离, 提供安全 IPC 的扩展接口, 移除内核中没有必要或有安全隐患的部分。Android 系统在继承 Linux 安全机制的同时, 也要考虑其移动平台的特殊性, 结合应用需求, Android 系统主要在以下几个方面提高系统的安全性

(1) Android 继承和扩展了 Linux 内核安全模型的用户与权限机制。在每个应用程序安装阶段, 赋予一个独立的 UID, 通常称为 app ID。应用执行时, 就在特定进程内以该 UID 运行。同时, 无论该进程是在原生还是在虚拟机内执行, 每个应用都有一个只有它才有读写权限的专用数据目录, 由此建立了内核级的应用沙盒。在 Linux 内核之上的程序库、虚拟机、系统服务和应用都可以运行在沙盒内。在一些操作系统中内存损坏是严重的安全隐患, 但在 Android 系统中由于应用的隔离, 内存的损坏只影响其对应的程序, 其他程序不受影响;

(2) 由于 Android 应用是沙盒隔离的, 它们只能访问自己的文件和一些设备上可全局访问的资源, 但这将限制 Android 的应用, 为此, Android 通过 AndroidManifest.xml 文件可以赋予应用额外的、细粒度的权限, 从而控制硬件设备、网络连接、数据或系统服务的访问;

(3) IPC Android 使用内核驱动和用户空间层的组合来实现 IPC 机制, 称为 Binder 机制。与 Linux 类似, Android 进程的地址空间是独立的, 一个进程不能直接访问另一个进程的内存空间, 即进程隔离。这种机制给系统带来稳定性和安全性的同时, 也阻隔了一个进程为另一个进程提供服务, 因此, Android 系统需要 IPC 机制帮助进程能够发现为其提供的服务并与之交互的进程。与 Windows 的 COM 和 Linux 的 CORBA 类似, Android 系统也采用一个基于抽象接口的分布式组件架构——Binder, 但与前者不同的是, Binder 机制更加灵活, 可靠性更高。它运行在单个设备上, 不支持 RPC 网络远程调用;

(4) 传统的 Android 安全模型严重依赖于应用的 PID, 虽然这是由内核提供的功能, 并且每个应用的文件都是私有的, 但无法完全禁止应用自身将它的文件改成全局可访问的文件。同理, 也无法禁止恶意应用程序利用系统文件或原生套接字过于宽松的访问标志位进行攻击。为此, Android 沿用了 Linux 安全增强技术 SELinux。

四、问答题

1、POSIX 是 IEEE 为 Linux 定制的可移植操作系统接口, 请简述 POSIX 的权能机制。

答:

(1) POSIX 权能机制是一种基于权能的最小特权控制机制, 其目的是实现比超级用户模式更细粒度的授权控制。它将特权划分成了一个权能集合;

(2) POSIX 权能机制提供了更为便利的权能管理和控制：一是提供了为系统进程指派一个权能去调用或执行受限系统服务的便捷方法；二是提供了一种使进程只能调用其执行特定任务必须权能的限制方法，支持最小特权安全策略的实现；

(3) POSIX 权能机制通过进程和程序文件权能状态(许可集、可继承集、有效权能集)，明确定义了进程如何获取和改变权能的语义，从而提供了一种基于进程所运行上下文控制进程权能的方法。

2、如何保护文件加密密钥（FEK）？一旦用户删除或系统重装，Windows 操作系统中的加密文件还能够恢复吗？

答：

(1) FEK 被用户数字证书公钥加密保护，还原 FEK 需要能够访问用户文件的加密证书私钥，这一私钥又得到用户主密钥的宝库，用户主密钥在用户口令的保护之下；

(2) 由于重置用户密码会失去原先的主密钥，从而失去访问 EFS 的访问能力，所以会导致不再能够打开原先使用 EFS 加密文件；

(3) 这种情况下，唯一的途径是在第一次加密文件时，备份 EFS 文件加密证书私钥。

第7章 数据库系统安全作业

一、填空题

- 1、数据库安全是保证数据库信息的机密性、完整性、可用性、可控性和隐私性，防止系统软件及其数据遭到破坏、更改和泄漏
- 2、数据库的结构分为内模式、概念模式、外模式。
- 3、数据库系统一般分为两个部分：数据库，管理软件（即数据库管理系统DBMS）。
- 4、数据库加密分为库内加密和库外加密。
- 5、安全审计的分析方法包括：潜在违规分析，基于异常检测的描述，简单攻击试探法，复杂攻击试探法。

二、选择题

- 1、以下描述正确的是（ B ）
 - A. 数据库在执行事务处理时，先操作数据库，再写日志；
 - B. 数据库在执行事务处理时，先写日志，再操作数据库；
 - C. 数据库在执行事务处理时，只需要操作数据库，不需要写日志；
 - D. 数据库在执行事务处理时，操作数据库和写日志同时进行。
- 2、用户访问数据库时，涉及以下哪些安全内容（ ABCDE ）
 - A. 授权规则；
 - B. 语义完整性检查；
 - C. 用户登录鉴别；
 - D. 数据加密；
 - E. 审计追踪
- 3、根据数据库的特点和实际需求，数据库加密必须满足以下要求（ ABCE ）
 - A. 对数据库加密对原有系统功能的影响不大；
 - B. 加解密的速度必须足够快，特别是对解密的速度要求更高；
 - C. 加密机制在理论上和计算上都具有足够的安全性；
 - D. 加密后的数据库存储量不增加，不能破坏字段长度的限制；
 - E. 加解密对数据库的合法用户是透明的。

4、数据库加密的粒度可以分为以下哪几类（ ABCFE ）

A.数据库； B.表； C.记录； D.页面； E.字段； F.数据项

三、简答题

1. 数据库加密方法应具备哪些要求？

答：

- （1） 由于数据库中的记录保存时间相对较长，因此加密算法的强度要求高；
- （2） 数据库加密以后，明密文数据长度相同或相当，不应明显增加，避免数据库管理系统有较大变动；
- （3） 对于大型数据库系统而言，数据库最常见的使用方式是随机访问，所以加解密速度要足够快，对数据操作响应时间的影响应在用户可接受的范围内；
- （4） 加密算法应该能够直接对记录或者字段进行加密

2、操作系统安全威胁和数据库安全威胁分别是什么？为什么不同？

答：

- （1） 操作系统安全威胁只有软威胁，主要包括：病毒、蠕虫和木马，逻辑炸弹，隐蔽通道，天窗等；
- （2） 数据库安全威胁主要包括：软威胁（病毒、蠕虫和木马，天窗或后门，隐蔽通道，逻辑炸弹）、硬威胁（存储介质故障、控制器故障、电源故障、芯片和主板故障）、人为错误、传输威胁、物理环境威胁。
- （3） 不同之处：数据库系统或多或少存在不同类型的安全漏洞；管理漏洞、数据库应用程序、操作系统等都可能会给数据库系统的安全带了很大的隐患。

四、问答题

1. 什么是数据库系统的安全策略？它包括哪几个方面，目的分别是什么？

答：数据库系统的安全策略是指导数据库系统安全的高级准则，即组织、管理、保护和处理敏感信息的原则，包括安全管理策略，信息流控制策略和访问控制策略；

-
- (1) 安全管理策略的目的是定义用户共享数据和控制它的使用；
 - (2) 信息流控制策略主要考虑如何控制一个程序去访问数据；
 - (3) 访问控制策略是数据库安全策略的重要组成部分，分为集中式控制和分布式控制两类，下分的策略包括：最小特权策略（让用户可以合法访问或修改数据库的前提下，分配最小的特权）、粒度适当策略、最大共享策略、开放和封闭系统策略、按访问类型划分的控制策略。

2.数据库的恢复技术包含哪些，各有什么特点？

答：

- (1) 事务故障的恢复。恢复子系统在不影响其他事务运行的情况下强行回滚该事务。具体做法是：利用日志文件撤销（UNDO）此事务已对数据库进行的修改，使得该事务好像根本没有启动一样。通常的做法是逆向扫描日志文件，对于日志记录的事务修改操作，将修改前的值写入数据库；
- (2) 系统故障的恢复。恢复子系统必须在系统重新启动后，让所有非正常终止的事务回滚，强行撤销（UNDO）所有未完成的事务，以保持事务的原子性，重做（REDO）所有已提交的事务以保持事务的持久性。从而保证数据库恢复到一致性的状态。重做的过程是正向扫描日志，对于事务的每一个修改记录，将修改后的值写入数据库。为了提高系统故障恢复的效率，可采用具有检查点（checkpoint）的系统故障恢复技术；
- (3) 介质故障的恢复。介质故障的恢复不仅要使用日志，还要借助于数据库备份。对于静态备份，恢复数据库备份后，数据库即出于一致性状态，然后利用日志重做故障前已经完成的事务，就能将数据库恢复到故障时刻相一致的状态；对于动态备份，恢复数据库备份后，数据库并不出于一致性的状态，还需要根据日志文件，利用系统故障恢复的方法，撤销备份结束时尚未完成事务对数据库的修改操作，并重做故障前已完成的事务，将数据库恢复到与故障时刻相一致的状态。

第 8 章 入侵检测技术作业和答案

一、填空题

1. 入侵是指任何试图破坏或危及信息系统资源的 完整性、机密性 和 可用性 的行为。
2. 入侵检测系统能够检测的入侵行为包括：试图闯入、成功闯入、冒充其他用户、违反安全策略、合法用户的泄露、独占及恶意使用资源。
3. 审计数据的预处理方法包括：数据集成、数据清理、数据变换、数据简化、数据融合。
4. 入侵信号的主要分析方法：模式匹配、统计分析、完整性分析。

二、选择题

1. 基于网络的入侵检测系统，需要把网卡设置成（ D ）
A. 单播模式； B. 广播模式； C. 多播模式； D. 混杂模式
2. 基于主机的入侵检测系统，需要收集以下哪些信息（ ACDE ）
A. 系统日志； B. 网络日志； C. 目录和文件中的异常改变； D. 程序中的异常行为； E. 物理形式的入侵信息
3. 下列关于包捕获机制的说法，正确的是：（ ABCD ）
A. 包捕获机制是依赖于操作系统
B. 包捕获机制是在数据链路层增加一个旁路处理器
C. 包捕获机制不影响网络协议栈对数据包的处理
D. 包过滤操作可以在用户空间或内核空间执行
4. 入侵检测的主动响应行为包括（ ABC ）
A. 断开网络连接； B. 杀死可疑程序； C. 对攻击系统实施反击； D. 增加审计日志； E. 向管理员报警

5. 实现交换网络的数据捕获的方法包括：（ABCD）

- A. 将数据包捕获程序安装在网络或代理服务器上。
- B. 对交换机实行端口映射，将所有端口的数据包全部映射到监控端口上。
- C. 在交换机和路由器之间连接一个 Hub，将数据以广播的方式发送。
- D. 采用 ARP 欺骗，在负责数据包捕获的设备上实现整个网络的数据包转发。

三、简答题

1. 入侵检测系统的优、缺点是什么？分析这些优、缺点给信息系统安全设计所带来的影响。

答：

（1）优点：提高信息安全体系中其他部分的完整性，提高系统的监控能力，能够从入口点到出口点跟踪用户的活动，能够识别和汇报文件的变化，能够检测系统配置错误并纠正，能够识别特殊攻击类型并向系统安全管理员汇报，进行自动防御；

（2）缺点：它无法弥补差的认证机制，不能弥补网络协议的弱点，不能弥补系统服务质量或完整性的缺陷，如果没有人的干预，不能管理攻击调查，不能指导安全策略的内容，不能分析一个堵塞的网络，不能处理有关 package-level 攻击；

（3）给信息系统安全设计带来的影响是：与其他安全技术，如：防火墙、身份认证、访问控制、安全审计等互补，但无法弥补这些系统本身的缺陷；可以为其他安全系统的完善提供有针对性的意见。

2. 分析包捕获机制的作用和局限性。

答：

（1）作用：在数据链路层增加一个旁路处理器，对发送和接收的数据包进行缓存和过滤等处理，最后直接送到应用程序。在这个过程中，包捕获机制并不影响网络协议栈对数据包的处理，它只是对所捕获的数据包根据用户的要求进行筛选，最终把满足过滤条件的数据包传递给应用程序；

（2）局限性：数据包从内核空间拷贝到用户空间开销很大。

3. 安全日志和审计数据的区别？

答：审计数据的范围更大，审计数据包含安全日志、主机内核数据、网络数据等等

四、问答题

1、举例说明基于协议分析的入侵检测系统。

答：

- (1) 基于协议分析的入侵检测系统是利用网络协议的高度规则性快速判断入侵行为；
- (2) 举例：suricata, snort

2、在入侵检测系统中，如何获取直接监测数据？举例说明

答：

- (1) 从数据的产生或从属的对象直接获得数据。
- (2) 例如：为了检测主机 CPU 的符合，可以直接从主机相应内核中获得数据。要检测 inetd 进程提供的网络服务，可以直接从 inetd 进程获取相关网络访问的数据。

第9章 可信计算作业

一、填空题

1. 一个可信平台必须包括三个可信根：可信度量根 RTM，可信存储根 RTS，可信报告根 RTR。
2. 平台证明引入了 AIK 对 PCR 值 和 随机数 N 在 TPM 的控制下的签名，保证了平台配置信息的 完整性 和 新鲜性，从而大大提高了通信的 安全性。
3. TPM 只允许两种操作来修改 PCR 的值：重置操作 和 扩展操作。
4. RTM 是平台启动时首先执行的一段程序，它是由 CRTM 控制的计算引擎。

二、选择题

1. 可信计算的安全属性不包括：（ B ）
A. 可鉴别性。 B. 可视性。
C. 完整性。 D. 机密性。
2. 可信计算中，一次度量就是一个度量事件，不包括如下度量事件：（ A ）
A. 完整性报告 B. 嵌入式数据。
C. 程序代码的特征值。 D. 被度量值的散列值。
3. TCG 认为可信平台不包含的可信根是：（ C ）
A. RTM B. RTS
C. PCR D. RTR
4. 下列说法正确的是：（ ABD ）
A. RTR 由 TPM 芯片中的 PCR 和背书密钥组成。
B. EK 可用于创建 TPM 的拥有者。
C. RTS 不包含 PCR。
D. EK 可用于创建 AIK 及其授权数据。
5. 下列可信根中包含 PCR：（ BC ）
A. RTM。 B. RTS。
C. RTR。 D. SRK。

三、简答题

1. 详细分析 PCR 在 TPM 所起到的作用。

答：

(1) PCR 可以使用非易失存储器或易失存储器实现；

(2) TCG 规定每一个 TPM1.1 中有 16 个 PCR，但这个数量太少，因此为了在有限的存储空间中保存平台自上电启动到应用程序加载所参与组件的所有度量信息，TCG 设计了一种方法，即：将需要度量的组件按照功能层次和度量的顺序进行归类，按照预定的顺序依次将度量结果叠加起来，只保存最后的度量结果。这种迭代计算散列值的方法，又称为“扩展（extend）操作”，即

$PCR[n] = SHA-1\{PCR[n-1]\} || newMeasurement$ 。由于度量顺序和组件都固定，因此，只要初始值一定，那么度量结果就是可预期的。PCR 只用于存储扩展后的度量结果。需要注意的是，由于 PCR 记录了平台状态的转换，因此平台转换操作必须要经过度量并扩展到 PCR 中，并且防止软件篡改 PCR 的值。

2. 简述可信计算中的信任根。

答：

(1) RTM：是平台启动时首先执行的一段程序，它是由 CRTM 控制的计算引擎。在理想状态下，CRTM 存储在 TPM 内部，但根据实现的需要，它可能需要加载到其他固件中，如 BIOS。

(2) RTS：由 TPM 芯片中的 PCR 和存储根密钥组成（SRK）组成。TCG 定义的各种密钥是按照树形结构进行组织和管理的，处于上级的父密钥的公钥对处于下级的子密钥进行加密保护，同时配合密钥访问控制机制，确保密钥体系的安全，存储密钥 SK 用于对其他密钥进行存储保护，它也是 RSA 密钥对。这些密钥是分级的，下级的密钥受到上级的存储密钥加密保护，从而构成一个密钥树。出于密钥树根部的密钥是最高级存储密钥，即存储根密钥 SRK，它是 2048 位的 RSA 密钥对，主要用于对 TPM 使用，但存储在 TPM 之外（如硬盘）的密钥进行保护。同时，他作为父密钥对其子密钥进行加密保护。

(3) RTR：由 TPM 芯片中的 PCR 和背书密钥（EK）组成。EK 仅用于以下两种操作：一是创建 TPM 的拥有者；二是创建 AIK 及其授权数据。EK 是唯一的，不做他用。一个 EK 唯一对应一个 TPM，一个 TPM 唯一对应一个平台，因此一个平台只有唯一一个 EK，它是平台的身份标识。AIK 是 EK 的替代物，也是 2048 位的 RSA 密钥。AIK 仅用于对 TPM 内部表示平台可信状态的数据和信息（PCR 值、时间戳、计算器值等数据）进行签名和验证签名，不用于数据加密。注：AIK 不能签名其他非 TPM 状态的数据，这样做的目的是防止攻击者伪造 PCR 让 AIK 签名。

3. 可信计算的基本功能是什么？

答：

（1）完整性度量、存储和报告

完整性度量是一个过程，是在可信平台启动过程中，组件（固件或软件）加载和执行之前，其度量散列值被扩展到了 TPM 内部的平台配置寄存器（PCR）中，通过计算该组件的散列值，并同期望值比较，就可以维护它们的完整性。

完整性报告则是用于验证平台的当前配置，证明完整性存储的过程，展示保护区域内存储的完整性度量值，依靠可信平台的鉴定能力判断存储值的正确性。

（2）平台证明

证明就是确认信息真实性的过程。通过这个过程，外部实体能够确认被保护区域额、受保护能力和信任根，而本地调用不需要证明。通过证明，完成了远程实体对平台身份的认证。由于引入了 AIK 对 PCR 值和随机数 N 在 TPM 的控制下的签名，保证了平台配置信息的完整性和新鲜性，从而大大提高了通信的安全性。

（3）受保护能力

受保护能力就是唯一被许可具有访问被保护区域的特权命令集，而被保护区域就是能够安全操作敏感数据的地方，如：内存、寄存器等。TPM 通过实现受保护能力和被保护区域，来保护和报告完整性度量值。

第 10 章 信息系统安全管理作业

填空题：

1. ISO/IEC 27001 标准，采用“计划 (P)—实施 (D)—检查 (C)—处置 (A)” (PDCA) 模型去架构所有信息系统管理体系的流程。
2. 信息系统安全管理的类型包括物理安全管理、系统安全管理、运行安全管理、数据安全管理、人员安全管理和技术文档安全管理。
3. 信息系统安全等级保护是从与信息系统安全相关的物理层面、网络层面、系统层面、应用层面和管理层面对信息和信息系统实施分等级保护。

选择题：

1. 信息系统安全管理措施中的运行安全管理不包括 (C)
A. 故障管理 B. 性能管理 C. 配置管理 D. 变更管理
2. 不属于信息系统安全管理措施主要类型的是 (B)
A. 管理控制 B. 访问控制 C. 技术控制 D. 物理控制
3. 属于信息系统安全管理措施中的人员安全管理原则之一是 (A)
A. 最小特权原则 B. 全员参与原则 C. 主要领导负责原则 D. 分权与授权原则
4. 启动 PDCA 循环的启动器应具有哪些条件 (ACDE)
A. 提供必需的资源 B. 确定管理范围 C. 选择风险管理方法 D. 确定评审方法 E. 文件化实践
5. PDCA 模型处置阶段可能持续进行以下哪些操作 (ABCD)
A. 测量信息系统安全管理体系满足安全方针和目标方面的业绩；
B. 识别信息系统安全管理体系的改进，并有效实施；
C. 采取适当的纠正和预防措施；
D. 针对结果，进行及时沟通，并与所有相关方磋商；
E. 记录并报告影响安全管理体系有效性的活动和事件。

简答题：

1. 信息系统安全管理的概念和五个组成要素（要素需简答说明）

答：

- (1) 概念：信息系统安全管理指计划、组织、领导、控制等环节来协调人力、物力、财力等资源，从而保证组织内的信息系统以及信息处理的安全；
- (2) 五个要素是：管理的主体、管理的客体、管理手段、管理环境、管理目标
 - a) 管理主体：指信息系统的安全由谁来管理；
 - b) 管理客体：指管理的对象是谁；
 - c) 管理手段：指管理流程、管理制度和管理方法；
 - d) 管理环境：指在什么情况、什么环境和什么条件下对信息系统安全实施管理；
 - e) 管理目标：指要达到的管理结果。

2. 如何理解信息系统安全管理中的分权和授权原则

答：

对特定职能或责任领域的管理功能实施分离、独立审计等分权，避免权力过于集中所带来的隐患，以减少未授权的修改或滥用系统资源的机会。任何实体（如用户、管理员、进

程、应用或系统)仅享有该实体需要完成其任务所必需的权限,不应享有任何多余权限。

3. 在信息系统安全管理措施中阐述的物理安全管理,与第 3 章的物理安全之间是什么关系?分析说明

答:

(1) 第 3 章的物理安全包含信息系统安全管理措施中的物理安全管理概念;

(2) 信息系统安全管理措施中的物理安全管理是第三章物理安全这一概念的具体实现;

分析:第 3 章物理安全的内涵更加丰富,不仅包括设备安全、环境安全和系统物理安全的定义,还包括具体的防护技术和管理标准和方法。信息系统管理措施中的物理安全管理仅仅包含物理安全的定义和管理方面的要求。

第 11 章 安全风险评估和等级保护作业和答案

一、填空题

- 1、信息系统建设的起点和源头是信息系统安全风险评估。
- 2、信息系统安全风险分析涉及资产、威胁、脆弱性等三个基本要素。
- 3、评价资产的三个安全属性是保密性、完整性、可用性。
- 4、威胁的基本属性包括威胁主体、资源、动机、途径。
- 5、信息系统基本安全需求包含基本安全技术需求和基本管理要求。
- 6、基本安全技术需求包含物理安全、网络安全、主机安全、应用安全和数据安全等 5 个层面。
- 7、基本管理要求包括安全管理制度、安全管理机构、人员安全管理、系统建设管理和系统运维管理等 5 个方面

二、选择题（包括单选和多选）

- 1、残余风险是由以下原因造成（ ABC ）
 - A. 安全措施不当造成的；
 - B. 安全措施失效造成的；
 - C. 综合考虑了安全成本与效益后未去控制造成的；
 - D. 组织机构变化后，引入的风险。
- 2、以下安全措施属于预防性安全措施的有（ ABD ）
 - A. 防火墙；
 - B. 入侵检测；
 - C. 入侵容忍；
 - D. 访问控制
- 3、以下说法正确的是（ AB ）
 - A. 根据威胁及威胁利用脆弱性的难易程度判断安全事件发生的可能性；
 - B. 根据威胁出现的频率和脆弱性的严重程度判断安全事件发生的可能性；
 - C. 根据资产的价值和脆弱性的严重程度判断安全事件发生的可能性；
 - D. 根据威胁出现的频率和资产的价值判断安全事件发生的可能性

4、以下说法正确的是（ ABDE ）

- A. 脆弱性识别需要具体到每个资产或组件上；
- B. 安全措施的确证不需要具体到每个资产或组件上；
- C. 保护性安全措施可以降低安全事件发生的可能性；
- D. 保护性安全措施可以减少安全事件发生后对组织或系统造成的影响；
- E. 安全措施的实是是以减少脆弱性或降低安全事件发生的概率为目标的。

5、以下说法正确的是（ D ）

- A. 资产的重要性可以选择保密性、完整性和可用性上的任何一个赋值表示；
- B. 资产的重要性只能综合考虑保密性、完整性和可用性上赋值；
- C. 资产的重要性取决于资产的经济价值；
- D. 资产的重要性取决于资产的价值。

6、以下哪种情况会出现欠保护（ B ）

- A. 在资产价值级别大于威胁级别的情况下，以威胁级别作为信息系统（安全域）的安全保护等级；
- B. 在资产价值级别小于威胁级别的情况下，以资产价值级别作为信息系统（安全域）的安全保护等级；
- C. 在资产价值级别与威胁级别相同的情况下，该级别则为信息系统（安全域）的安全保护等级；
- D. 根据信息系统安全等级不同，采用不同的安全措施。

三、简答题

1、信息系统安全风险评估的概念？

答：信息系统安全风险评估是根据国家有关信息安全技术标准，对信息系统及其处理、传输和存储信息的安全属性进行科学评估的过程，即评估信息系统的脆弱性，所面临的威胁以及脆弱性被威胁源利用后对系统造成的负面影响，并根据安全事件发生的可能性和负面影响来识别信息系统的安全风险。

2、在什么情况下进行信息系统安全风险评估？

答：

- （1） 在设计规划或升级信息系统时。前者是在信息系统建立时，通过信息系统安全风险评估，将安全体系或机制的建设和系统的建设同步进行，有利于为信息系统建立完整和全面的防护体系；后者是在现有的信息系统升级时，其安全威胁和安全需求可能发生改变，此时需要对其风险重新评估。
- （2） 目前的信息系统需要增加新的应用或新的扩充时，其运行环境可能发生变化，造成其威胁源发生变化，从而需要重新对其进行风险评估，进一步确定新的安全需求。
- （3） 发生一次安全事件后，意味着原有的安全威胁分析不够全面，有所遗漏，此时需要重新评估其风险。
- （4） 组织发生结构性变动时，信息系统的运行环境将发生变化，管理人员和运行、使用系统的人员可能发生变化，需要对信息系统安全风险重新评估。
- （5） 按照某些规定或特殊要求，对信息系统的安全进行评估时。

3、信息系统安全风险评估的可控性原则是什么？

答：在风险评估项目实施过程中，应严格按照标准的项目管理方法对服务过程、人员和工具进行控制，以确保风险评估实施过程中的可控和安全。

- （1） 服务可控性。评估放应实现在评估工作沟通会议中，向用户介绍评估服务流程，明确需要得到被评估组织写作的工作内容，确认安全评估服务工作的顺利进行。
- （2） 人员与信息可控性。所有参与评估的人员均应进行严格的资格审查和备案，明确其职责分工，应签署保密协议，以保证项目信息的安全；应对工作过程数据和结果数据严格管理，未经授权不得泄露给任何单位和个人。
- （3） 过程可控性。应按照项目管理的要求，成立项目实施团队，采用项目组长负责制，达到项目过程的可控。

-
- (4) 工具可控性。安全评估人员所使用的评估工具应该事先告诉用户，并在实施前获得用户的许可，包括产品本身，测试策略等。

4、什么情况下会造成残余风险？

答：

- (1) 由于安全措施不当或无效造成的；
- (2) 综合考虑了安全成本和效益后未去控制的风险。

5、风险评估工具选择的原则？

答：

- (1) 实际需要原则。首先必须清楚风险评估工具的运行平台和应用平台，选购时要注意工具是否能够检测最新操作系统所特有的安全问题，同时还要留意工具除了对 TCP/IP 协议进行分析外，还应该能够对其他网络协议进行分析。
- (2) 试用原则。评估一个工具是否满足用户的要求，最好的办法是在购买前，测试或试用一下，在用户的实际环境和系统下看看工具能否有效运行。
- (3) 实用原则。为了提高实用性，风险评估工具不仅能够找出特定系统的安全弱点，帮助管理员修补漏洞，而且能够提供风险分析报告。一个好的风险评估工具具有良好的人机界面，具有依托互联网的强大服务功能，能够通过互联网为用户提供有关漏洞的详细说明、风险程度、修补措施等。
- (4) 满足脚本数量与更新速度要求。评估工具的脚本数量并不一定与漏洞的数量成正比。优秀的风险评估工具能够将每一种漏洞链接到一个标准的漏洞案例上。必须留意工具的更新频率，看它是自动更新的，还是手工更新的，以及发现威胁后，它需要多长时间才能推出新版本。
- (5) 支持不同级别的入侵检测。所有风险评估工具都有这样的警告：入侵检测过程可能产生 DoS 攻击或导致受测试系统挂起。一般的，在高访问量期间，对担负关键任务的系统不应运行风险评估工具。原因是风险评估

工具本身可能引起服务终端或系统死机。大多数高级的风险评估工具允许执行侵害程度较小的入侵测试，以免造成系统运行终端。

四．计算题

1、假设：某信息系统有 3 个重要的资产 $A_1=2$ ， $A_2=1$ ， $A_3=3$ ，，其中 A_1 面临三个主要威胁 $T_1=1$ ， $T_2=5$ ， $T_3=4$ ； A_2 面临两个主要威胁 $T_4=3$ ， $T_5=4$ ； A_3 面临两个主要威胁 $T_6=3$ ， $T_7=4$ 。威胁 T_1 可以利用资产 A_1 存在的一个脆弱性 $V_1=3$ ；威胁 T_2 可以利用资产 A_1 存在的两个脆弱性 $V_2=1$ ， $V_3=5$ ；威胁 T_3 可以利用资产 A_1 存在的一个脆弱性 $V_4=4$ 。威胁 T_4 可以利用资产 A_2 存在的一个脆弱性 $V_5=4$ ；威胁 T_5 可以利用资产 A_2 存在的一个脆弱性 $V_6=3$ 。威胁 T_6 可以利用资产 A_3 存在的一个脆弱性 $V_7=2$ ；威胁 T_7 可以利用资产 A_3 存在的一个脆弱性 $V_8=3$ 。

计算各资产在不同威胁和脆弱性下的风险值，判定各风险值的风险等级。
答：

资产	威胁	脆弱性	发生概率 L	损失 F	风险值 R	等级
资产 $A_1=2$	$T_1=1$	$V_1=3$	$\sqrt{3}$	$\sqrt{6}$	$3\sqrt{2}$	1
	$T_2=5$	$V_2=1$	$\sqrt{5}$	$\sqrt{2}$	$\sqrt{10}$	1
	$T_2=5$	$V_3=5$	5	$\sqrt{10}$	$5\sqrt{10}$	4
	$T_3=4$	$V_4=4$	4	$2\sqrt{2}$	$8\sqrt{2}$	3
资产 $A_2=1$	$T_4=3$	$V_5=4$	$2\sqrt{3}$	2	$4\sqrt{3}$	2
	$T_5=4$	$V_6=3$	$2\sqrt{3}$	$\sqrt{3}$	6	2
资产 $A_3=3$	$T_6=3$	$V_7=2$	$\sqrt{6}$	$\sqrt{6}$	6	2
	$T_7=4$	$V_8=3$	$2\sqrt{3}$	3	$6\sqrt{3}$	2

假设判定等级是

1-5 1 级； 6-10 2 级； 11-15 3 级； 16-20 4 级； 21-25 5 级